Task Name: Theory of VAPT Methodology

Name: Kavita Prajapati

Tools Overview:

1. NMAP

- **Nmap (Network Mapper)** is an open-source network scanning tool used to discover hosts and services on a network. It helps security professionals identify open ports, running services, operating systems, and potential security vulnerabilities in a target system. Nmap is widely used during the reconnaissance phase of penetration testing to map the network and understand the attack surface.

2. OPENVAS

- **OpenVAS (Open Vulnerability Assessment System)** is an open-source vulnerability scanning tool used to detect security weaknesses in systems and networks. It performs automated scans to identify known vulnerabilities, misconfigurations, and outdated software versions. OpenVAS provides detailed reports including CVE references, severity levels, and remediation recommendations, making it useful for vulnerability assessment tasks.

3. OWASP ZAP

- **OWASP ZAP (Zed Attack Proxy)** is an open-source web application security testing tool developed by the **OWASP** community. It is used to detect vulnerabilities in web applications such as Cross-Site Scripting (XSS), SQL Injection, and security misconfigurations. ZAP can perform automated scans, spider websites, and analyze HTTP traffic, making it a powerful tool for web application penetration testing.

Theoretical Study:

Introduction:

Now a day's modern organizations, protecting digital systems and sensitive information has become extremely important. Cybersecurity threats are increasing, making it necessary for organizations to regularly evaluate the security of their systems. Security assessments and penetration testing are key processes that help identify vulnerabilities and measure how strong a system's defenses are. This study focuses on the theoretical concepts behind security assessments, including vulnerability assessment, penetration testing methods, security standards, risk evaluation, and proper documentation practices. It also highlights several open-source tools and frameworks that are commonly used in cybersecurity assessments.

Understanding Security Assessment:

A **security assessment** is a systematic process used to identify vulnerabilities, weaknesses, and misconfigurations in information systems. The primary goal of a security assessment is to evaluate how secure a system is and identify potential risks that could be exploited by attackers.

Types of Security Testing:

Vulnerability Assessment:

A vulnerability assessment focuses on identifying known vulnerabilities within systems and networks. Automated scanners such as OpenVAS and OWASP ZAP are commonly used to detect outdated software, misconfigurations, and known security flaws.

Penetration Testing:

Penetration testing simulates real-world cyberattacks to determine whether vulnerabilities can be exploited. Tools such as Nmap and Metasploit Framework are frequently used by security professionals to discover open ports, identify services, and test potential exploits.

Compliance Testing:

Compliance testing ensures that systems adhere to security standards and industry guidelines. Organizations commonly use checklists such as the CIS Benchmarks to validate that systems follow recommended security practices.

VAPT Methodology:

Vulnerability Assessment and Penetration Testing (VAPT) follows a structured methodology that helps security professionals systematically identify and validate vulnerabilities.

Planning Phase:

The planning phase defines the scope, objectives, and rules of engagement for the assessment. During this stage, the target systems and testing boundaries are established. Tools such as Dradis can be used to organize project information and maintain documentation.

Discovery Phase:

In this phase, information about the target system is collected through reconnaissance and scanning activities. Tools such as Nmap are used to identify open ports and services, while OWASP ZAP is used to detect vulnerabilities in web applications.

Attack Phase:

During the attack phase, discovered vulnerabilities are tested through controlled exploitation. The Metasploit Framework allows security professionals to simulate attacks and validate whether vulnerabilities can be exploited by attackers.

Reporting Phase:

The final stage of the VAPT process involves documenting all findings, risk levels, and recommended mitigation strategies. Reporting tools and templates help security teams communicate vulnerabilities and remediation steps effectively.

Security Standards & Compliance:

Organizations follow security standards and regulatory frameworks to ensure that their systems meet required security and privacy requirements.
Some widely recognized standards include:

- General Data Protection Regulation – Protects personal data and privacy of individuals.
- Health Insurance Portability and Accountability Act – Protects healthcare information.
- ISO/IEC 27001 – Provides guidelines for establishing an Information Security Management System.

For web application security, organizations often prioritize vulnerabilities using the OWASP Top 10, which highlights the most critical web security risks such as injection attacks, broken authentication, and security misconfigurations.

Risk Assessment Basics:

Risk assessment helps organizations prioritize vulnerabilities based on their potential impact and likelihood of exploitation.

CVSS Scoring System:

The Common Vulnerability Scoring System (CVSS) provides a standardized method for assessing vulnerability severity. Security analysts often use the CVSS calculator provided by the National Vulnerability Database to determine vulnerability scores.

Score Range	Risk Level
0 – 3.9	**Low**
4 – 6.9	**Medium**
7 – 8.9	**High**
9 – 10	**Critical**

Risk Matrix:

A risk matrix is another method used to prioritize vulnerabilities based on their likelihood and impact.

Vulnerability	Likelihood	Impact	Risk Level
SQL Injection	High	High	Critical
Cross-Site Scripting	Medium	Medium	Medium
Open Ports	Low	Medium	Low

Common Vulnerability:

Security assessments often identify vulnerabilities in both network infrastructure and web applications.

Network Vulnerabilities:

Nework vulnerabilities typically include:

- Open or unnecessary ports
- Weak authentication mechanisms
- Outdated services

Tools such as Nmap are commonly used to identify these issues.

Web Application Vulnerabilities:

Common web vulnerabilities include:

- SQL Injection
- Cross-Site Scripting (XSS)
- Broken authentication

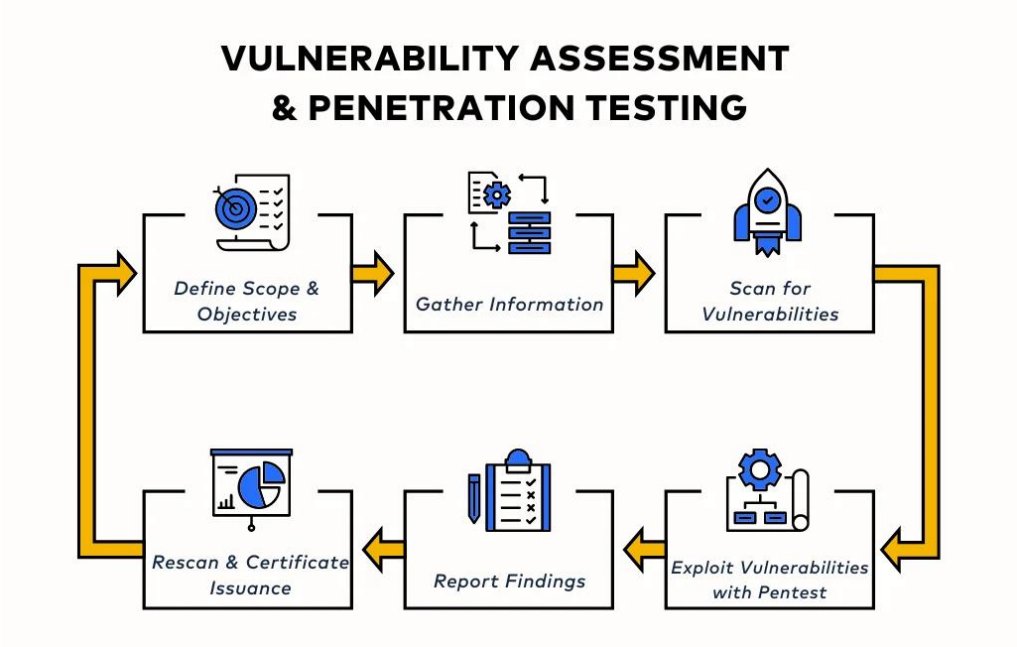
Practice platforms such as OWASP Juice Shop and Metasploitable allow learners to safely explore these vulnerabilities in a controlled environment.

Documentation Fundamentals:

Proper documentation is an essential part of any security assessment. Security professionals must record findings, evidence, and remediation recommendations in a structured report.

Common tools used for documentation include:

- Dradis – Used for collaboration and report generation
- CherryTree – Used to organize technical notes and findings



This image describe the **process of Vulnerability Assessment and Penetration Testing (VAPT)** used to identify and fix security weaknesses in systems.

Summary:

1. **Define Scope & Objectives** – Decide which systems, applications, or networks will be tested and set the goals.
2. **Gather Information** – Collect details about the target system (reconnaissance).
3. **Scan for Vulnerabilities** – Use automated tools to detect potential security flaws.

4. **Exploit Vulnerabilities (Pentest)** – Test the discovered weaknesses to see if they can actually be exploited.
5. **Report Findings** – Document vulnerabilities, risks, and recommended fixes.
6. **Rescan & Certificate Issuance** – After fixes are applied, the system is rescanned to confirm security improvements.

For Reference:

https://www.nist.gov/cyberframework (Cybersecurity Framework)

https://nvd.nist.gov/vuln-metrics/cvss (Common Vulnerability Scoring System)

https://www.iso.org/isoiec-27001-information-security.html (Information Security Management Systems)

Vulnerability Assessment Report:

Information:

Item	Details
Project Title	Vulnerability Assessment of Metasploitable and Kali Linux Environment
Assessment Type	Vulnerability Assessment Lab
Tools Used	Kali Linux, OpenVAS, Nikto, Nmap
Target System	Metasploitable
Testing Environment	VirtualBox Lab
Date	13/03/2026

Executive summary:

The objective of this assessment was to identify security vulnerabilities in a controlled testing environment using open-source security tools. The assessment was performed on a vulnerable virtual machine to simulate a real-world security evaluation scenario.

The scanning process identified several vulnerabilities including outdated software versions, exposed services, and configuration weaknesses. These issues could potentially allow attackers to gain unauthorized access to the system if not properly mitigated. Risk assessment was performed using CVSS scoring to prioritize remediation efforts.

Tools Used:

Tool	Purpose
Kali Linux	Security testing platform
Nmap	Port Scanning
Nikto	Web server security testing
Oracle VM VirtualBox	Virtual lab environment

Methodology:

The vulnerability assessment followed a structured process consisting of the following phases:

1. Environment setup using virtual machines
2. Vulnerability scanning using OpenVAS
3. Web server analysis using Nikto
4. Risk assessment using CVSS scoring
5. Documentation and reporting of findings

The below table gives a brief description of each risk rating visualized in this report.

Impact	CVSS Score	Definition
Critical	9.0 – 10.0	Critical vulnerabilities are the highest level of security risks, demanding immediate attention and mitigation within an organization. They pose an imminent and severe threat, with the potential for unauthorized access, data breaches, or significant system compromise. Swift remediation is crucial to maintain robust security.
High	7.0 – 8.9	High severity vulnerabilities should be considered a top priority in terms of mitigation. These are the most severe issues and generally cause an immediate security concern to the enterprise
Medium	4.0 – 6.9	Medium severity vulnerabilities are a lower priority but should still be remediated in a timely manner. These are

		moderate exploits that have less of an impact on the environment.
Low	0.1 – 3.9	Low severity vulnerabilities are real but trivially impactful to the environment. These should only be remediated after the HIGH and MEDIUM vulnerabilities are resolved.
Informational	0.0	Informational vulnerabilities have no impact as such to the environment by themselves. However, they might provide an attacker with information to exploit other vulnerabilities.

The following control areas are the easiest to exploit or expose the environment to the highest level of risk:

Sr. No.	Vulnerability Name	Severity Level
1	Missing X-Content-Type-Options Header(MIME Sniffing)	**Medium**
2	Missing X-Frame-Options Header	**Medium**
3	Network Service Exposure	**Low**

Sr.No. 1	**Name of Vulnerability:** Missing X-Content-Type-Options Header(MIME Sniffing)	**CWE Details:** CWE-16
Medium	**CVSS Score:** 5.3	

Vulnerable URL: http://testfire.net/

Description: The server does not include the **X-Content-Type-Options header**. Without this header, browsers may perform **MIME type sniffing**, which means they may interpret files as a different content type than intended.

Impact: Browsers may execute malicious scripts disguised as other file types. Could lead to **Cross-Site Scripting (XSS)** in some cases.

Step to Reproduce:

Step 1: Open the Kali Linux terminal and Execute the Nikto scan on the target web application.

Step 2: The scan output displays the following message: “The X-Content-Type-Options header is not set.”

Step 3: This behaviour could allow malicious files or scripts to be executed in the browser under certain conditions.

Recommendation:

- Enable the **X-Content-Type-Options header**.

Reference: https://httpsecurityheaders.com/X-Content-Type-Options

Sr.No. 2	**Name of Vulnerability:** Missing X-Frame-Options Header	**CWE Details:** CWE-1021
Medium	**CVSS Score:** 4.3	

Vulnerable URL: http://testfire.net/

Description: The web server does not include the **X-Frame-Options HTTP response header**. This header prevents the website from being embedded inside an iframe on another malicious website. Without this protection, attackers may perform **Clickjacking attacks**, tricking users into clicking hidden elements or performing unintended actions.

Impact:
Attackers can trick users into:

- Clicking hidden buttons
- Performing unintended transactions
- Changing account settings

Step to Reproduce:

Step 1: Open the Kali Linux terminal and Run the Nikto web vulnerability scanner against the target website.

Step 2: Nikto scans the web server configuration and HTTP headers.

Step 3: During the scan, Nikto analyzes whether security headers are implemented.

Step 4: The scan result shows the following message: “The anti-clickjacking X-Frame-Options header is not present.”

Step 5: The absence of this header indicates a Clickjacking protection misconfiguration**.**

```
└─# nikto -h https://testfire.net
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Multiple IPs found: 65.61.137.117, 64:ff9b::413d:8975
+ Target IP:          65.61.137.117
+ Target Hostname:    testfire.net
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=demo.testfire.net
                   Ciphers:  ECDHE-RSA-AES256-GCM-SHA384
                   Issuer:   /C=GB/ST=Greater Manchester/L=Salford/O=Sectigo Limited/CN=Sectigo RSA Domain Validation Secure Server CA
+ Start Time:         2026-03-12 05:33:44 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache-Coyote/1.1
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The site uses TLS and the Strict-Transport-Security HTTP header is not defined. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.co
m/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
```

Recommendation:

- Implement the **X-Frame-Options header** in the web server configuration.

Reference:
https://cheatsheetseries.owasp.org/cheatsheets/Clickjacking_Defense_Cheat_Sheet.html

Sr.No. 3	**Name of Vulnerability:** Network Service Exposure	**CWE Details:** CWE-200
Low	**CVSS Score:** 3.7	
Vulnerable IP: 10.60.221.85		
Description: The target system responds to **ICMP echo requests (ping)**, confirming that the host is active on the network. While ports appear closed or filtered during the **Nmap scan**, the system still reveals its presence to external users.		
Impact: Attackers can use this information during the **reconnaissance phase** to map the network and identify live hosts for further attacks.		
Step to Reproduce: Step 1: Find target ip and run ping “target ip”. Step 2: After confirming the response scan target ip with nmap –sV “target ip”. Step 3: Check the Result. But in this PoC there is no any open ports during scanning.		

```
msfadmin@metasploitable:~$ ping 10.60.221.85
PING 10.60.221.85 (10.60.221.85) 56(84) bytes of data.
64 bytes from 10.60.221.85: icmp_seq=1 ttl=255 time=6.08 ms
64 bytes from 10.60.221.85: icmp_seq=2 ttl=255 time=12.7 ms
64 bytes from 10.60.221.85: icmp_seq=3 ttl=255 time=3.39 ms
64 bytes from 10.60.221.85: icmp_seq=4 ttl=255 time=6.64 ms

--- 10.60.221.85 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 3.394/7.225/12.778/3.434 ms
msfadmin@metasploitable:~$ nmap 10.60.221.85

Starting Nmap 4.53 ( http://insecure.org ) at 2026-03-06 04:21 EST
All 1714 scanned ports on 10.60.221.85 are closed

Nmap done: 1 IP address (1 host up) scanned in 5.633 seconds
msfadmin@metasploitable:~$ nmap -sV 10.60.221.85

Starting Nmap 4.53 ( http://insecure.org ) at 2026-03-06 04:23 EST
All 1714 scanned ports on 10.60.221.85 are filtered

Service detection performed. Please report any incorrect results at http://insec
ure.org/nmap/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 40.005 seconds
msfadmin@metasploitable:~$ _
```

Recommendation:

- Implement **strict firewall policies**
- Monitor network scanning attempts
- Regularly perform **internal VAPT scans**
- Enable **logging for ICMP and scan detection**

Reference: https://cwe.mitre.org/

Conclusion:

The vulnerability assessment was carried out using a structured approach. First, a testing environment was created using virtual machines to safely perform the assessment. After setting up the environment, the web server was then analyzed using **Nikto** to detect common web-related vulnerabilities. The identified vulnerabilities were evaluated using **CVSS scoring** to determine their severity and risk level. Finally, all findings were documented and organized into a report along with relevant evidence and recommendations.